



Penetration Testing Report: Bounty Hacker (TryHackMe)

Target IP Address: 10.112.135.128

Date: June 19, 2026

Difficulty: Easy

1. Executive Summary

A comprehensive security assessment was performed against the target IP 10.112.135.128. The assessment revealed multiple misconfigurations, including exposed anonymous file sharing (FTP) and weak credential management. By leveraging information leaked over FTP, an attacker was able to brute-force an SSH account and subsequently abuse high-privilege system binaries (tar) to gain complete administrative access (root) to the machine.

2. Port Scanning & Enumeration

An initial Nmap service scan revealed three open ports:

Port	Protocol	State	Service	Version / Info
21	tcp	Open	FTP	vsftpd 3.0.5 (Anonymous Login Allowed)
22	tcp	Open	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.13
80	tcp	Open	HTTP	Apache httpd 2.4.41 ((Ubuntu))

Key Findings from Nmap:

- **Port 21 (FTP):** Indicated that Anonymous login was explicitly allowed on the server.
- **Port 80 (HTTP):** A standard web server hosting a landing page without an HTML page title.

3. Initial Access (Exploitation)

Step 1: FTP Data Harvesting

Logging into the FTP server anonymously revealed information files containing conversations and a list of potential strings.

- **Username Discovered:** Analysis of the data revealed a valid system user: `lin`.
- **Wordlist Generated:** A list of 26 potential passphrase variations was extracted (including target variants like `rEddrAGON`, `r3ddr@g0N`, and `RedDr4gonSynd1cat3`).

Step 2: SSH Brute-Forcing

Using the isolated username and custom password wordlist, an online brute-force attack was executed against the active SSH service (Port 22) using `Hydra`.

- **Result:** Successful credential match found.
- **Valid Credentials:** `lin` : `RedDr4gonSynd1cat3`

```
Bash
# Valid connection string
ssh lin@10.112.135.128
```

🏆 User Flag Captured

Upon gaining low-privilege shell access as the user `lin`, the user flag was located in the home directory:

User Flag: `THM{CR1M3_SyNd1C4T3}`

4. Privilege Escalation (Post-Exploitation)

Local Enumeration

To find a path to administrative execution, a check for absolute sudo permissions was run:

```
Bash
lin@bountyhacker:~$ sudo -l
```

The output revealed that the user `lin` could execute the archiving utility binary `/bin/tar` as root without providing a password (`NOPASSWD`).

Exploitation via SUID/Sudo Breakout

The `tar` utility features custom `--checkpoint` flags that allow arbitrary command execution when handling compression tasks. By initiating a null-archive and passing an execution string to drop into `/bin/sh`, the security restrictions were bypassed:

```
Bash
sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
```

Result: Immediate privilege elevation to the `root` identity.

Root Flag Captured

The root flag was obtained within the system administrator's secure directory:

Root Flag: `THM{80UN7Y_h4cK3r}`

5. Remediation Recommendations

1. **Disable Anonymous FTP:** Disable configuration policies that allow unauthenticated users (`anonymous`) to connect or access system lists on Port 21.
2. **Enforce Strong Password Policies:** Ensure system users utilize robust, complex, and un-brute-forcable system passwords that do not map to common online dictionary variants.
3. **Apply Principle of Least Privilege:** Modify the `/etc/sudoers` file configuration. Restrict low-privilege users from executing powerful utilities like `tar`, `find`, or text editors with root permissions unless explicitly necessary, or restrict the usage parameters tightly.